

APT28 — Forest Blizzard

Threat Actor Profile | Aviation & Aerospace

Published: 2026-05-29 | Profile ID: LBC-AP-2026-006 | TLP: AMBER

Prepared by: Lost Boys Cyber — Threat Intelligence Team

AI-ASSISTED REPORT — IMPORTANT DISCLOSURE

This profile was generated with AI assistance. All TTPs, IOCs, attribution assessments, and detection rules must be independently validated by a qualified analyst before operational use, external distribution, or legal/regulatory action.

Attribution Warning: Nation-state attribution is probabilistic. Confidence levels reflect analytical assessment only — not proof.

1. At a Glance

Attribute	Value
Primary Alias	APT28
MITRE ATT&CK Group	G0007 — https://attack.mitre.org/groups/G0007/
Nation-State Sponsor	Russia — GRU Military Intelligence (Unit 26165 / Unit 74455)
Motivation	Espionage: NATO/defence intelligence; sabotage capability; influence operations
Active Since	2008 (confirmed); likely earlier
Activity Status	Active — elevated tempo 2024–2025 (CISA advisory May 2025)
Sophistication	Nation-state elite — zero-day exploitation history; extensive custom toolchain
Primary Sectors	Aerospace, Defence, NATO entities, Government, Logistics, Technology, Media
Primary Geographies	NATO countries, Eastern Europe, US, UK, France, Germany, Poland; global reach
Assessment Confidence	High — US/UK/EU official attribution; DOJ indictments (12 GRU officers)

2. Identity & Aliases

Vendor	Designation
Microsoft	Forest Blizzard (formerly STRONTIUM)
CrowdStrike	Fancy Bear
Mandiant / Google	APT28
ESET	Sednit
Kaspersky	Sofacy
Secureworks	IRON TWILIGHT
Recorded Future	BlueDelta
MITRE ATT&CK	G0007
US DOJ / CISA	GRU Unit 26165; 12 officers indicted in Mueller investigation

3. Attribution Assessment

Assessment: Russia — GRU Unit 26165. Confidence: High.

APT28 attribution is among the most thoroughly documented of any state-sponsored group: a 2018 US DOJ indictment named 12 GRU Unit 26165 officers by name; subsequent UK NCSC, EU, and Five Eyes official attribution statements corroborate. For aerospace and defence, APT28 represents a dual threat: sustained intelligence collection against Western contractors and NATO organisations, combined with a demonstrated sabotage capability through its overlap with Sandworm/Unit 74455 operations.

The May 2025 CISA joint advisory (AA25-141A) specifically named APT28/GRU Unit 26165 as targeting Western logistics entities and technology companies coordinating support for Ukraine — placing aerospace and defence contractors directly in the threat picture.

Evidence Type	Detail	Confidence
DOJ indictment	2018: 12 GRU Unit 26165 officers named; charges include CFAA, wire fraud, identity theft	High
Official attribution	US, UK, EU, Australia, Canada, New Zealand collectively attributed APT28 to GRU	High
X-Agent exclusivity	X-Agent/Sofacy backdoor exclusively attributed to APT28 across 15+ years of operation	High
Targeting alignment	NATO, aerospace, defence, logistics — aligns with GRU intelligence collection mandate	High
CISA AA25-141A	May 2025 joint advisory specifically addresses APT28 Western logistics/aerospace targeting	High

4. Background & History

APT28 (Forest Blizzard) is Russia's GRU Military Intelligence cyber arm and one of the most prolific state-sponsored threat groups globally. For aerospace and defence, APT28 pursues two objectives: long-term intelligence collection against NATO military aviation systems and defence contractors, and — particularly since Russia's 2022 invasion of Ukraine — targeting any organisation involved in coordinating Western military and logistical support.

The group's 2024–2025 tradecraft evolution is significant: reconstituted password spraying capability routing brute-force traffic through Tor; Operation RoundPress exploiting XSS vulnerabilities in enterprise webmail (Roundcube, Zimbra, MDAemon, Horde); and a new implant, Prismex, combining steganographic C2 with COM hijacking persistence and wiper commands — indicating sustained R&D investment despite public exposure.

Date	Event	Significance
2008	First observed	Earliest attributed APT28

		intrusions; Eastern European government targeting
2014–2016	NATO/aerospace espionage	Defence contractors and NATO member targeting confirmed
2016	DNC breach / US election interference	High-profile operation; broad public awareness of APT28
2018	GRU indictment	12 GRU officers named; Unit 26165 publicly identified
2022	Ukraine-conflict acceleration	Dramatic tempo increase; NATO aerospace/defence/logistics in scope
2023–2024	Operation RoundPress	XSS exploitation of Roundcube, Zimbra, MDaemon, Horde webmail
2024	Password spray via Tor	Reconstituted credential spray infrastructure; routing via Tor
May 2025	CISA advisory AA25-141A	Multi-agency: APT28 targeting Western logistics/tech supporting Ukraine
2025	Prismex deployment	New implant: steganographic C2 + COM hijacking + wiper commands

5. TTPs — MITRE ATT&CK

Tactic	Technique	Observed	Frequency	Notes
Initial Access	T1566.001 — Spearphishing	Yes	High	Targeted aerospace/defence personnel; document lures
Initial Access	T1078 — Password Spraying	Yes	High	Via Tor; O365/webmail brute force — 2024–2025 primary vector
Initial Access	T1190 — Exploit Public-Facing App	Yes	High	XSS in Roundcube, Zimbra, MDaemon, Horde (Operation RoundPress)
Execution	T1059.001 —	Yes	High	Post-exploitation

	PowerShell			scripting
Execution	T1059.005 — Visual Basic	Yes	Med	Macro-enabled Office lures
Persistence	T1053.005 — Scheduled Task	Yes	High	Long-term persistence on contractor networks
Persistence	T1574.001 — DLL Side-Loading	Yes	Med	Prismex uses COM hijacking for persistence
Defence Evasion	T1027.003 — Steganography	Yes	Med	Prismex encodes C2 communications in image files
Defence Evasion	T1078.004 — Cloud Accounts	Yes	Med	Abuses cloud services for C2 traffic blending
Credential Access	T1110.003 — Password Spraying	Yes	High	Tor-proxied spray; O365/Azure AD primary targets
Credential Access	T1114.002 — Remote Email Collection	Yes	High	Mailbox access post-RoundPress exploitation
Lateral Movement	T1021.001 — RDP	Yes	Med	Internal lateral movement on compromised networks
Collection	T1114.001 — Local Email Collection	Yes	High	Email archive theft from aerospace contractors
C2	T1573.002 — Asymmetric Cryptography	Yes	High	Encrypted C2; X-Tunnel custom encryption protocol
Impact	T1485 — Data Destruction	Suspected	Low	Prismex wiper commands; coordination with Unit 74455

6. Toolset

Tool	Type	Purpose	Attribution
------	------	---------	-------------

			Confidence
X-Agent (Sofacy)	Full RAT	Flagship espionage implant; keylogging, file exfil, screenshot, C2	High — exclusive 15+ years
X-Tunnel	Tunnel tool	Encrypted communications tunnel; custom encryption protocol	High — exclusive
Prismex	Multi-function implant	Steganographic C2 + COM hijacking persistence + wiper commands	High — 2025 release
HeadLace	Backdoor	NATO-targeting campaigns 2023–2024; modular	High
LOOBACK	Backdoor	Lightweight persistent access implant	High
Zebrocy	Loader/Downloader	Delphi-based first-stage; delivers full implants	High
Mimikatz	Credential tool	Post-compromise credential dumping	Low — commodity

7. Detection

7.1 Sigma — Operation RoundPress Webmail XSS

```

title: APT28 — Webmail XSS Injection (Operation RoundPress)
id: d1e2f3a4-b5c6-7890-defa-678901230007
status: experimental
description: JavaScript injection in webmail query parameters — APT28 RoundPress
pattern
references:
  - https://attack.mitre.org/groups/G0007/
  - https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141a
author: Lost Boys Cyber | date: 2026-05-29
tags:
  - attack.initial_access
  - attack.t1190
logsource:
  category: webserver
detection:
  selection:
    cs-uri-query|contains:
      - "<script"
      - "javascript:"
      - "onerror="
      - "document.cookie"
      - "eval("
  condition: selection
falsepositives:

```

```
- Security scanner traffic; allowlist scanner source IPs
level: high
```

7.2 Sigma — Password Spray via Tor Exit Nodes

```
title: APT28 — Authentication Failures from Tor Exit Nodes
id: d2e3f4a5-b6c7-8901-efab-789012340008
status: experimental
description: Failed 0365 auth from IPs in Tor exit node list — APT28 spray
tradecraft
tags:
  - attack.credential_access
  - attack.t1110.003
logsource:
  product: azure
  service: signinlogs
detection:
  selection:
    ResultType: "50126"
    UserAgent|contains: "python-requests"
  timeframe: 5m
  condition: selection | count() by IPAddress > 10
falsepositives:
  - Automated testing tools; validate source IP against Tor exit list
level: high
```

7.3 KQL — Steganographic C2 (Prismex Pattern)

```
// APT28 Prismex: Process making outbound HTTP requests with image file extensions
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl matches regex @".(png|jpg|gif|bmp)?[a-zA-Z0-9]{20,}"
| where InitiatingProcessFileName !in~ (
    "chrome.exe", "msedge.exe", "firefox.exe", "iexplore.exe",
    "svchost.exe", "MicrosoftEdgeUpdate.exe")
| project Timestamp, DeviceName, AccountName,
    InitiatingProcessFileName, RemoteUrl, RemoteIP
| order by Timestamp desc
```

7.4 KQL — Webmail XSS Lateral Movement

```
// APT28 RoundPress: Roundcube/Zimbra server spawning unexpected child processes
DeviceProcessEvents
| where Timestamp > ago(90d)
| where InitiatingProcessFileName in~
("roundcube", "zimbra", "httpd", "apache2", "nginx")
    or InitiatingProcessCommandLine has_any ("roundcube", "zimbra")
| where FileName in~ ("cmd.exe", "powershell.exe", "sh", "bash", "python", "perl")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName,
    ProcessCommandLine
| order by Timestamp desc
```

8. Threat Hunting

8.1 Hunt: Password Spray Detection (Tor-Proxied)

Hypothesis: APT28 routes spray traffic via Tor; failed auth events will originate from Tor exit node IPs against multiple accounts.

```
SigninLogs
| where TimeGenerated > ago(30d)
| where ResultType == "50126"
| summarize FailedAttempts=count(), UniqueAccounts=dcount(UserPrincipalName)
  by IPAddress, bin(TimeGenerated, 5m)
| where UniqueAccounts > 5
| order by FailedAttempts desc
// Cross-reference IPAddress against Tor exit node threat feed
```

8.2 Hunt: X-Agent / HeadLace Artefacts

Hypothesis: X-Agent and HeadLace leave characteristic registry and file artefacts on compromised hosts. Hunt for their known persistence mechanisms.

```
DeviceRegistryEvents
| where Timestamp > ago(90d)
| where ActionType == "RegistryValueSet"
| where RegistryKey has_any
  ("CurrentVersion\Run", "CurrentVersion\RunOnce", "Services")
| where InitiatingProcessFileName !in~ (
  "msiexec.exe", "setup.exe", "install.exe", "svchost.exe", "services.exe")
| project Timestamp, DeviceName, AccountName,
  RegistryKey, RegistryValueName, RegistryValueData
| order by Timestamp desc
```

9. Recommended Defensive Posture

- Patch enterprise webmail immediately — Operation RoundPress targets Roundcube, Zimbra, MDaemon, Horde XSS vulnerabilities; if any of these are deployed, treat patching as emergency priority or migrate to hosted Exchange Online/Google Workspace.
- Block authentication from Tor exit nodes — APT28's 2024–2025 spray routes through Tor; Conditional Access or firewall rules blocking known Tor exit node IP ranges directly defeats this vector.
- Enforce phishing-resistant MFA across all O365/Azure AD accounts — password spray is defeated by hardware MFA tokens; TOTP is not sufficient (can be relayed).
- Deploy X-Agent/HeadLace/Prismex YARA signatures — APT28's custom toolset has well-documented signatures; ensure EDR YARA coverage includes 2024–2025 variants.
- Review logistics and supply chain communications access — CISA AA25-141A specifically calls out logistics/tech organisations coordinating Ukraine support; audit which logistics partners have network access and enforce zero-trust segmentation.
- Monitor for steganographic C2 patterns — Prismex encodes C2 in image file requests; deploy network anomaly detection for HTTP requests with unusually long query strings appended to image URLs.

10. References

- [1] MITRE ATT&CK. "APT28 — G0007." <https://attack.mitre.org/groups/G0007/>
- [2] CISA. "Russian GRU Targeting Western Logistics." <https://www.cisa.gov/news-events/cybersecurity-advisories/aa25-141a>
- [3] LogPoint. "APT28 Forest Blizzard: New Arsenal." <https://logpoint.com/en/blog/emerging-threats/forest-blizzard>

- [4] SOC Prime. "Detect APT28 attacks against logistics." <https://socprime.com/blog/detect-apt28-attacks-against-western-companies-coordinating-aid-to-ukraine/>
- [5] Hunt & Hackett. "Threat actor profile: Fancy Bear." <https://www.huntandhackett.com/threats/actors/apt28>
- [6] ThreatIntelReport. "APT28 Profile." https://www.threatintelreport.com/2026/02/20/threat_actor_profiles/threat-actor-profile-apt28/